대외비(Confidential)

웹 애플리케이션 모의해킹 진단 결과 보고서 (샘플)

수행: **(주)비젼솔루션** | 종합 등급: 주의

진단 대상	[고객사 사이트 URL] (워드프레스 기반)	**진단 기간**	20XX-XX-XX ~ (1~2일)
진단 유형	실전 모의해킹(블랙박스+인증)	**사용 도구**	OWASP ZAP · Nuclei · WPScan (+수동)
진단 근거	사전 서면 동의(신청·동의서)	**원칙**	비파괴 — 변경·삭제 없음

※ 본 문서는 **샘플**이며, 아래 발견 항목은 당사 소유 테스트용 워드프레스를 실제 진단한 결과입니다(가공 없음).

1. 종합 결과

치명적(서버 장악) 취약점은 없으나, **구버전 플러그인·계정 이름 노출·XML-RPC 노출**이 겹쳐 관리자 계정을 겨냥한 침입 위험이 높아지는 구조입니다. 아래 중간 위험 4건 우선 조치를 권고합니다. (높음 0 · 중간 4 · 낮음 3)

2. 발견 항목 상세

번호	항목	위험도	근거(엔진 실제 탐지)	조치
F-01	구버전 플러그인 — Contact Form 7	중간	readme.txt에서 5.3.1 확인(최신 6.1)	최신 업데이트·자동갱신
F-02	구버전 플러그인 — WP Super Cache	중간	readme.txt에서 1.7.1 확인(최신 3.0.0)	최신 업데이트
F-03	관리자 계정 이름 노출(사용자 열거)	중간	?author=1·feed/rdf·wp-json/users 로 계정명 노출	사용자 열거 차단, 로그인/표시이름 분리
F-04	XML-RPC 인터페이스 노출	중간	xmlrpc.php 응답+listMethods 호출 가능	미사용 시 차단, 사용 시 IP·속도 제한
F-05	워드프레스 버전 노출	낮음	메타·wp-links-opml에서 6.3.2 식별	버전 숨김+코어 업데이트
F-06	설정·안내 파일 노출	낮음	readme.html·license.txt 외부 접근	접근 차단

F-07	관리자 로그인 페이지 노출	낮음	wp-login.php 노출	2단계 인증·접근 제한

3. 조치 우선순위

① 플러그인·코어 업데이트(F-01·02·05) → ② 계정 노출 차단+2단계 인증(F-03·07) → ③ XML-RPC 차단/제한(F-04) → ④ 노출 파일 차단(F-06)

4. 재점검(2차)

조치 후 같은 항목을 다시 진단해 **1차 대비 해결/미해결 차이표**를 본 보고서에 덧붙여 제공합니다(서비스 1회 포함).

5. 데이터 폐기

수집 자료(스캔 원본·캡처·접속정보)는 **2차 재점검 완료 후 복구 불가능하게 완전 폐기**하며, 폐기 사실을 데이터 폐기 확인서로 발급합니다.

본 보고서는 진단 시점 기준이며 이후 변경분은 별도 진단이 필요합니다. 결과에 따른 운영 책임은 이용자에게 귀속됩니다. | 문의: biztalktome@gmail.com